AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictive) · KRL-ADM — console d'administration IAM

Lead auditor: **Attest CI** Owner: **DSI — équipe IAM** Date: **2026-11-03 23:47**

Run: **iam**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

OPINION AFTER REMEDIATION

Needs improvement

7 controls tested	**6** findings	**5** findings closed and verified	**1** open findings
0 human approvals · 5 pre-approved (demo)	**8** sensitive data items masked in evidence	**1 min 17 s** audit duration	**$0.121 *** measured AI cost



Critical: 1 High: 2 Medium: 3 Low: 0

Key messages

- 6 findings across 7 controls: 1 critical, 2 high, 3 medium.
- 5 findings fixed through change management, then verified by re-testing.
- 1 finding remains open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Banque Kerlann (fictive)
System	KRL-ADM — console d'administration IAM
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	Attest CI
Date	2026-11-03 23:47
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Audited target	KRL-ADM IAM admin console (Banque Kerlann)

Work programme existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Non-compliant	Compliant	Closed — verified	2026-12-03
F-02	PSI-4.2	Mandatory MFA for users of critical system	High	Non-compliant	Compliant	Closed — verified	2027-02-01
F-03	PSI-4.7	No generic or shared admin accounts	High	Non-compliant		Action plan	2027-02-01
F-04	PSI-4.3	Strong password policy	Medium	Non-compliant	Compliant	Closed — verified	2027-05-02
F-05	PSI-4.4	Account lockout after failed logins	Medium	Non-compliant	Compliant	Closed — verified	2027-05-02
F-06	PSI-4.5	Inactive session timeout	Medium	Non-compliant	Compliant	Closed — verified	2027-05-02

–	PSI-4.6	Logging of administration actions	High	Compliant

4. Detailed findings and controls

F-01 PSI-4.1 Mandatory MFA for privileged accounts

Critical · Non-compliant → Compliant

Closed — verified

CRITERIA

MFA is enforced for all privileged admin accounts on KRL-ADM

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`
Expected: `true`

GET /api/security returned mfa_admin=False.

RISK

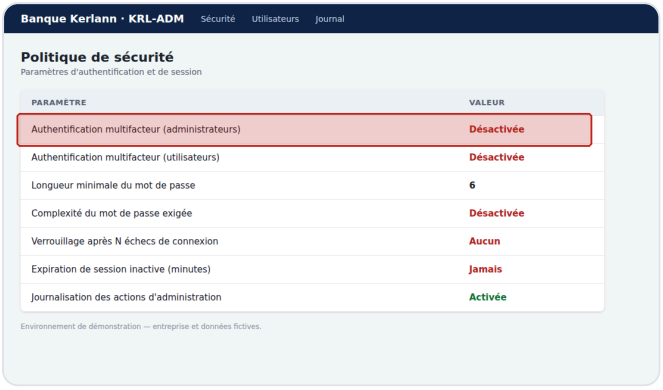
Without MFA for admins, stolen credentials allow full takeover of critical functions with no second barrier

RECOMMENDATION

Enable mandatory MFA for all privileged accounts by setting mfa_admin to true

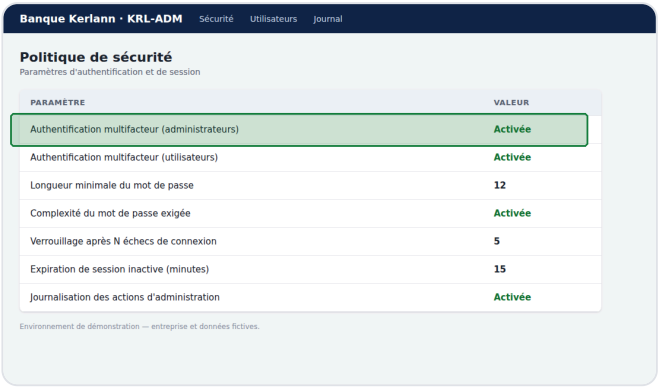
Due date: 2026-12-03 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_admin is true



At testing — The screenshot corroborates the test. The security policy table shows administrator MFA as disabled, matching the failed test.

2026-11-03 23:48:10 · SHA-256 015edda87da9c0da…



After fix — The screenshot corroborates the test. The screenshot shows administrator MFA is set to Activée, matching mfa_admin true.

2026-11-03 23:49:02 · SHA-256 48b118b50b0694c7…

> **Change request CHG-AUD-2026-IAM-01-01** · `PATCH /api/security {"mfa_admin": true}`
> Mandatory MFA for privileged accounts must be enforced to remediate failed control C1.
> Expected impact: Admin users will be required to use MFA at next login and must enroll if not already configured.
> Approved by: **IAM owner (CI)** · 2026-11-03 23:48:51 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-03T23:48:51Z · svc-change · mfa_admin: False → True

F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant → Compliant

Closed — verified

CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`

Expected: `true`

mfa_users is False.

RISK

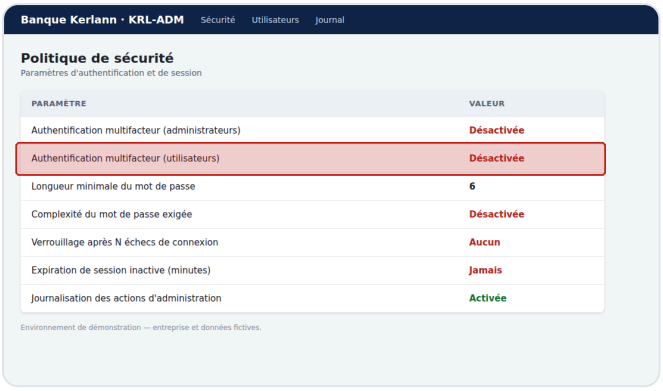
Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true

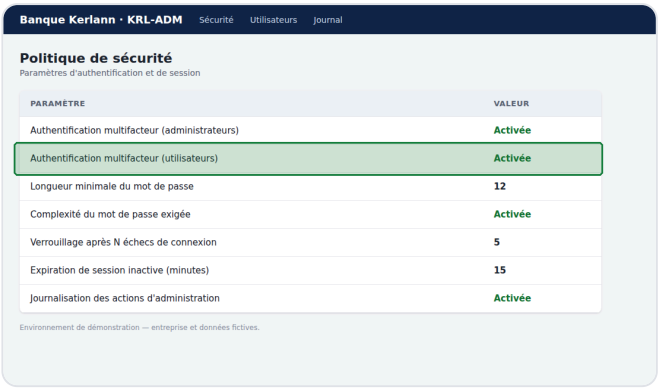
Due date: 2027-02-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true



At testing — The screenshot corroborates the test. The screenshot shows MFA for standard users as Disabled, matching the automated test failure.

`2026-11-03 23:48:14 · SHA-256 b820452f7484f994…`



After fix — The screenshot corroborates the test. The screenshot shows MFA for standard users as Activée, matching the automated pass result.

`2026-11-03 23:49:02 · SHA-256 2d0c5ac482222289…`

> **Change request CHG-AUD-2026-IAM-01-02** · `PATCH /api/security {"mfa_users": true}`
> Mandatory MFA for standard users is required to protect critical functions and it is currently disabled.
> Expected impact: Standard users will be required to use MFA on next login.
> Approved by: **IAM owner (CI)** · 2026-11-03 23:48:51 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-03T23:48:51Z · svc-change · mfa_users: False → True

F-03 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Action plan

CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)

CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`

Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 2 admin account(s) violate nominative login or personal email requirements.

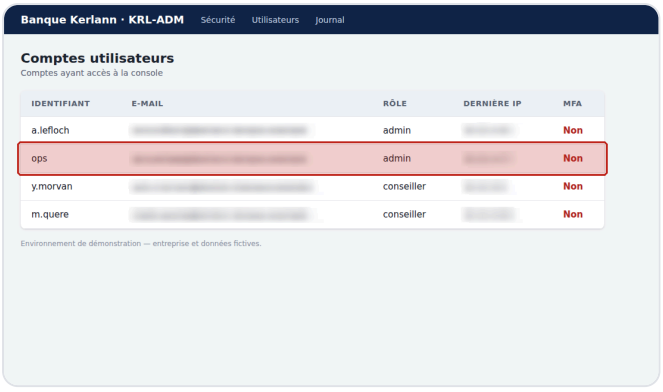
RISK

RECOMMENDATION

Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts
Due date: 2027-02-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox



At testing — The screenshot corroborates the test. The screenshot shows admin ops with generic login and shared mailbox ops-partage, confirming the automated failure. · 8/8 sensitive data items masked
`2026-11-03 23:48:37 · SHA-256 5f0e3f5f9fed5941…`

Manual remediation · CHG-AUD-2026-IAM-01-03
The generic shared admin account ops destroys individual accountability and must be replaced with dedicated nominative accounts.

1. Disable and remove the generic/shared admin account with login 'ops' and email 'ops-partage@kerlann-banque.example'.
2. Identify the individuals using the shared account and provision each with a dedicated nominative admin account with initiale.nom login and personal email.
3. Verify via GET /api/users that all remaining admin accounts satisfy nominative login and personal email requirements.

F-04 PSI-4.3 Strong password policy

Medium · Non-compliant → Compliant

Closed — verified

CRITERIA

Passwords require a minimum length of 12 characters with complexity requirements enabled
PSI-4.3 · DORA 9(4)(d)

CONDITION

Observed: `{"password_min_length": 6, "password_require_complexity": false}`
Expected: `password_min_length >= 12 AND password_require_complexity == true`
password_min_length is 6 and password_require_complexity is False.

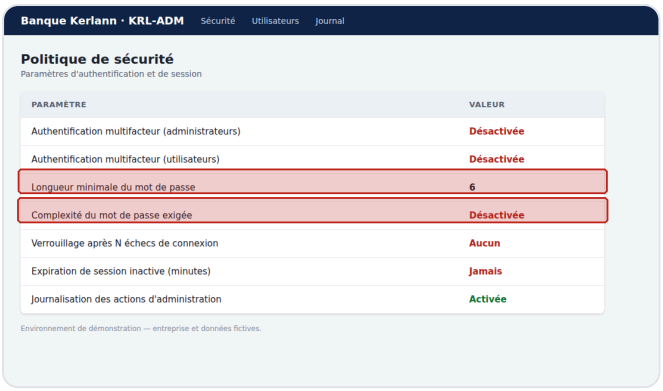
RISK

Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

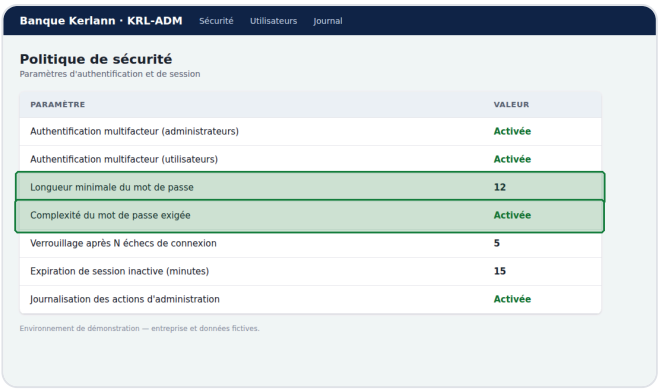
RECOMMENDATION

Enforce a minimum password length of 12 characters with complexity by correcting the password settings
Due date: 2027-05-02 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity



At testing — The screenshot corroborates the test. The screenshot shows minimum password length 6 and password complexity disabled, matching the automated failure.
`2026-11-03 23:48:13 · SHA-256 59f709b6f387c261…`



After fix — The screenshot corroborates the test. Screenshot shows minimum password length of 12 and password complexity enabled.
`2026-11-03 23:49:07 · SHA-256 d4ee818f3121357a…`

> **Change request CHG-AUD-2026-IAM-01-04** · `PATCH /api/security`
> `{"password_min_length": 12, "password_require_complexity": true}`
> Increases minimum password length to 12 and enables complexity to meet PSI-4.3.
> Expected impact: Users will be required to choose longer complex passwords at next password change.
> Approved by: **IAM owner (CI)** · 2026-11-03 23:48:51 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-03T23:48:51Z · svc-change · password_min_length: 6 → 12; password_require_complexity: False → True

F-05 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant → Compliant

Closed — verified

CRITERIA

Accounts lock after at most 5 failed login attempts and lockout is never disabled
PSI-4.4 · DORA 9(4)(c)

CONDITION

Observed: `0`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`
lockout_threshold is 0, which is outside the required range 1 to 5 inclusive.

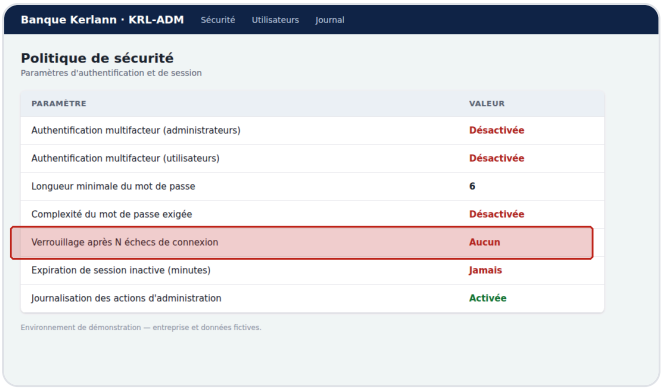
RISK

Without lockout, attackers can perform unlimited password-guessing attacks against accounts

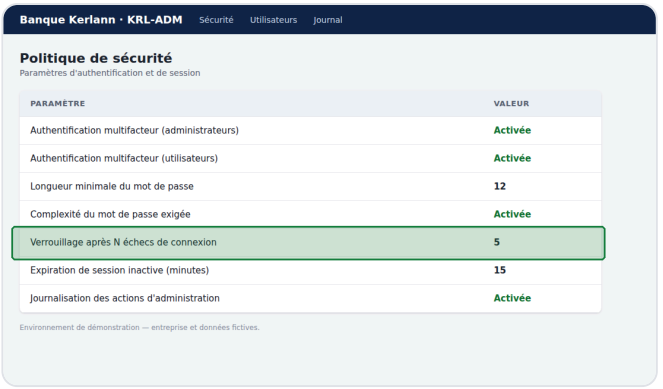
RECOMMENDATION

Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5
Due date: 2027-05-02 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive



At testing — The screenshot corroborates the test. The security policy shows lockout after failed logins as Aucun, confirming the threshold of 0.
`2026-11-03 23:48:13 · SHA-256 66abf7ad5d69463f…`



After fix — The screenshot corroborates the test. The screenshot shows Verrouillage après N échecs de connexion set to 5, matching the automated test result.
`2026-11-03 23:49:04 · SHA-256 6e5f94cd5b41e614…`

> **Change request CHG-AUD-2026-IAM-01-05** · `PATCH /api/security {"lockout_threshold": 5}`
> Set lockout_threshold to 5 to bring account lockout into the required 1 to 5 range.
> Expected impact: Accounts will lock after 5 consecutive failed logins and will require unlock or reset.
> Approved by: **IAM owner (CI)** · 2026-11-03 23:48:51 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-03T23:48:51Z · svc-change · lockout_threshold: 0 → 5

F-06 PSI-4.5 Inactive session timeout

Medium · Non-compliant → Compliant

Closed — verified

CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled
PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `0`
Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`
Observed session_timeout_minutes is 0, outside the required 1 to 15 inclusive.

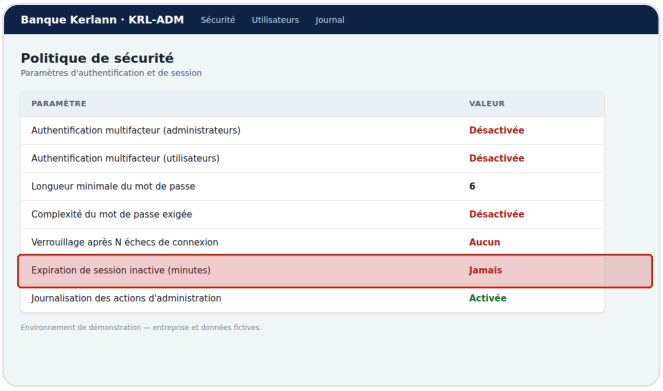
RISK

Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

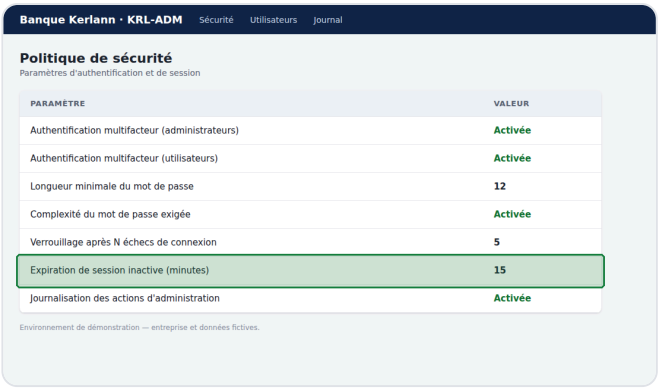
RECOMMENDATION

Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15
Due date: 2027-05-02 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive



At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to Jamais, confirming the timeout is disabled.
`2026-11-03 23:48:23 · SHA-256 34c5651f61799e87…`



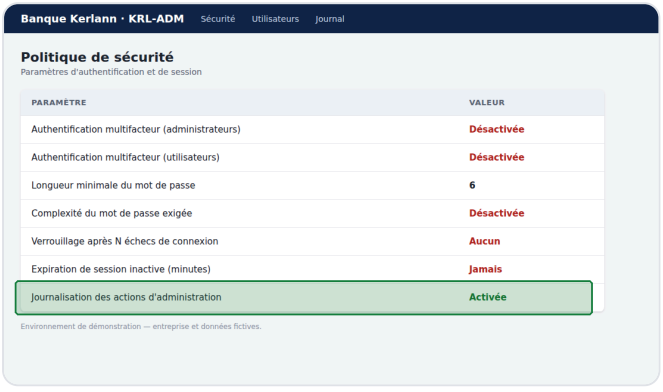
After fix — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 15 minutes.
`2026-11-03 23:49:13 · SHA-256 3ba30f1088538a75…`

> **Change request CHG-AUD-2026-IAM-01-06** · `PATCH /api/security`
> `{"session_timeout_minutes": 15}`
> Observed value 0 disables expiration so setting it to 15 restores compliance with the 1 to 15 minute requirement.
> Expected impact: Inactive sessions will expire after 15 minutes and require re-authentication.
> Approved by: **IAM owner (CI)** · 2026-11-03 23:48:51 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-03T23:48:51Z · svc-change · session_timeout_minutes: 0 → 15

PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`



At testing — The screenshot corroborates the test. The screenshot shows administration action logging as Activée, matching the automated pass result.
`2026-11-03 23:48:26 · SHA-256 07036fd4bb987f6b…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Non-compliant → Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-03 23:48:10	015edda87da9c0da3d4326e8965a9b767d69edfa8070aa9f06a93452e7c8c443
evidence/C1_after.png	C1 · After fix	2026-11-03 23:49:02	48b118b50b0694c7dec3bebae0e8d4b73569c57a2d109030b595170b63ced3de
evidence/C2_before.png	C2 · At testing	2026-11-03 23:48:14	b820452f7484f99425f14f699c4361017351bcf089e209bb55b404f19de0156d
evidence/C2_after.png	C2 · After fix	2026-11-03 23:49:02	2d0c5ac48222228963668a550e60a8389c3ecab2528447d7ff60ce8259ce8352
evidence/C3_before.png	C3 · At testing	2026-11-03 23:48:13	59f709b6f387c261ba35f8e70b766a8b39235c60df1b38d9412dc0c9df6945ea
evidence/C3_after.png	C3 · After fix	2026-11-03 23:49:07	d4ee818f3121357af94f1a8cdbdaa3ae5a321e9ffcc1b7255c2cc6ce742b727f
evidence/C4_before.png	C4 · At testing	2026-11-03 23:48:13	66abf7ad5d69463f92ea5ea8670a5ae7df8e31b8bd2ffa2969d3edde2270a22b
evidence/C4_after.png	C4 · After fix	2026-11-03 23:49:04	6e5f94cd5b41e61434c3d555ec48a3d91cc46c0791db4a0b09b74e615d0f0e65

evidence/C5_before.png	C5 · At testing	2026-11-03 23:48:23	34c5651f61799e87efcbb4339416bfefbe09faa51e33584b403151d9e79348b3
evidence/C5_after.png	C5 · After fix	2026-11-03 23:49:13	3ba30f1088538a75d86bb2433ef15a67dec7f8c403f4df39931fed5e140ce60c
evidence/C6_before.png	C6 · At testing	2026-11-03 23:48:26	07036fd4bb987f6bdd5e3d59d80d6d762164b60af73816d4cb60265a331c87a3
evidence/C7_before.png	C7 · At testing	2026-11-03 23:48:37	5f0e3f5f9fed5941c42d1230f8d28d379cc0a49afd5033cab59caa676e0548a5
evidence/journal.png	System journal		8ea7906866d364e0954f39283de4971d934db996921ea339ac4771c45da3cb34

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	18	22,585	21,815	0	0.1209
sam-3.1	12	0	0	12	price not published
Total					**0.1209**

Sensitive data (personal data and secrets) in evidence: 8/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Human decisions

TICKET	REF.		APPROVED BY	MODE	DATE
CHG-AUD-2026-IAM-01-01	F-01	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-03 23:48:51
CHG-AUD-2026-IAM-01-02	F-02	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-03 23:48:51
CHG-AUD-2026-IAM-01-04	F-04	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-03 23:48:51
CHG-AUD-2026-IAM-01-05	F-05	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-03 23:48:51
CHG-AUD-2026-IAM-01-06	F-06	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-03 23:48:51

Safeguards

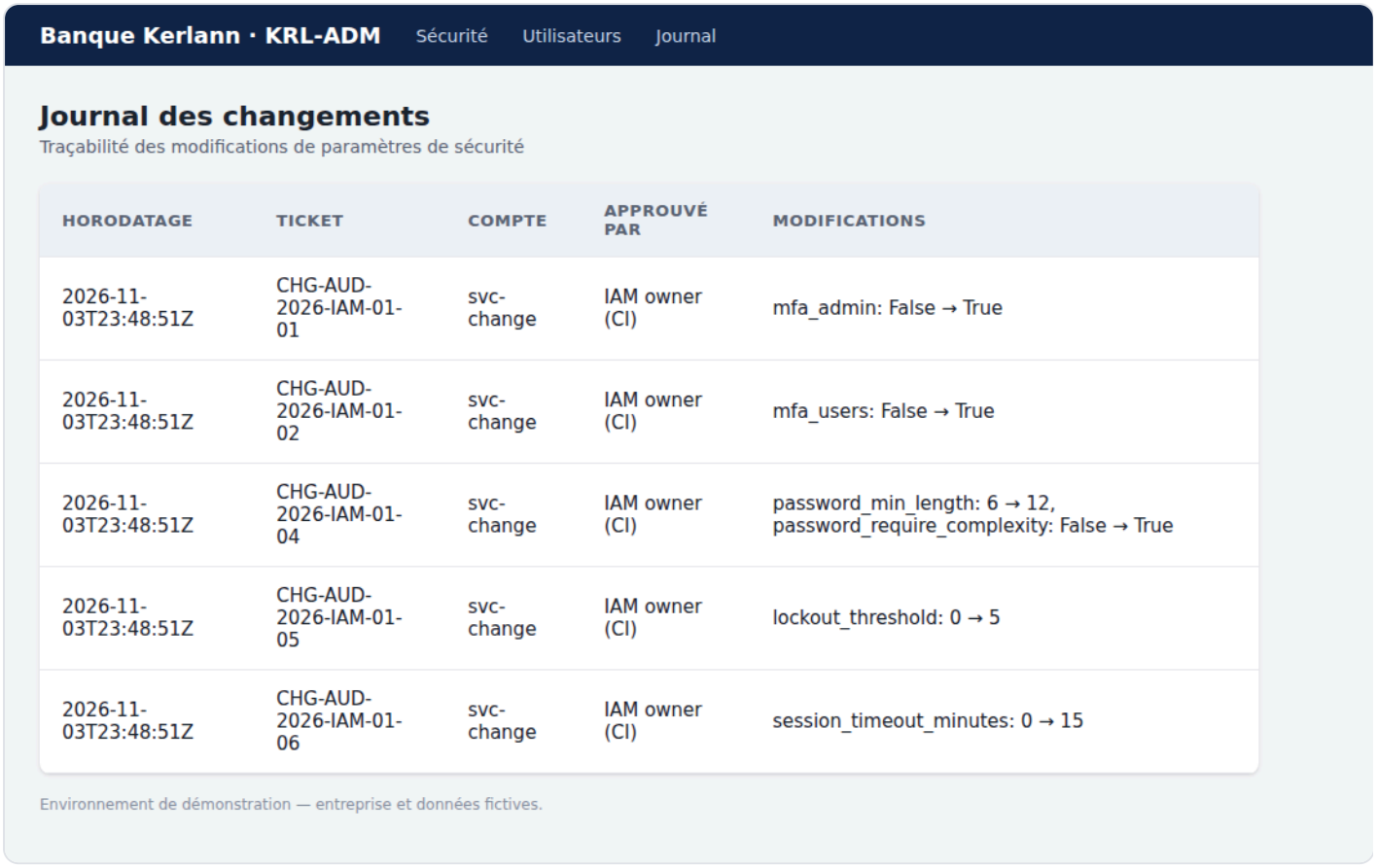
- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`7e076d263bbd0493ece1bc0cbf7e0f8a61fb0e77a627106f529364ade3e4790b`

E. Change log of the audited system



`SHA-256 8ea7906866d364e0954f39283de4971d934db996921ea339ac4771c45da3cb34`